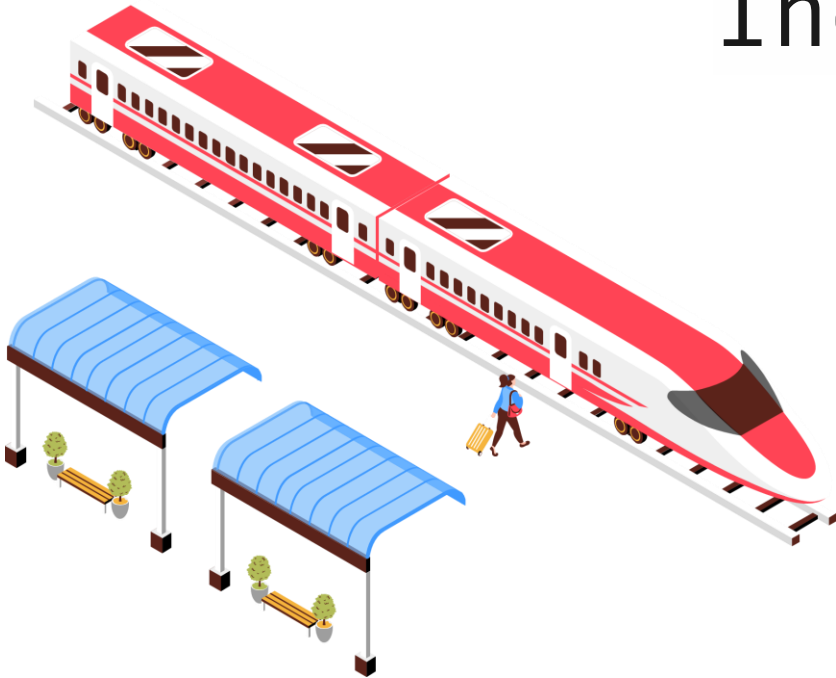


Cyber-security in Industrial Control Systems



**Kawtar Zerhouni, Maîtresse de conférences
UTER MID@S - ECC**



CM1 : Introduction to Industrial Cybersecurity

- We explored Industrial Control Systems, their component and their importance.
- We introduced CIA triad
- We looked at key differences between IT and OT systems

Wait, what exactly are we aiming to safeguard ICS systems against?

Threats landscape



CM2 : Threats and vulnerabilities

- We explored possible threats and attacks to ICS
- We identified vulnerabilities that enable these threats.
- We presented some vulnerability analysis tools
- We introduced risk assessment processing paving our way to Risk Score per vulnerability Calculation

What actions should we do to prevent these incidents ?

Security Monitoring



CM3 : Security Monitoring

Passive monitoring

Active monitoring

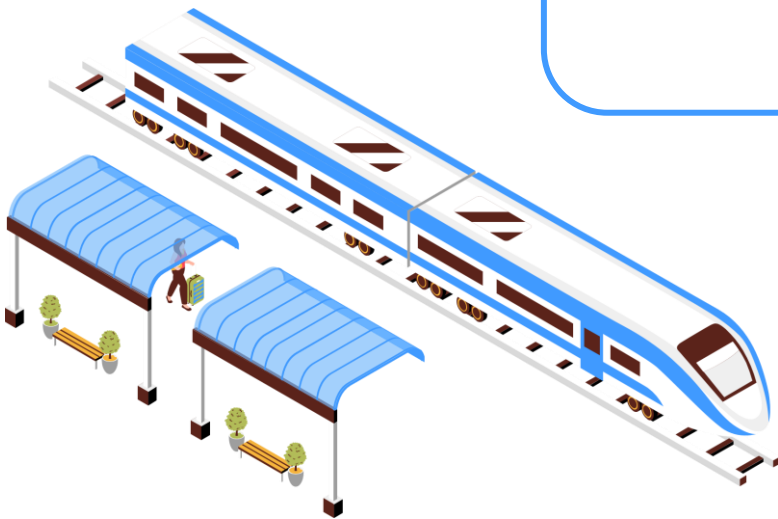
Threat hunting

From isolated events to attack understanding

What should be done in case of a cybersecurity incident in an ICS environment?

CM4 : Incident Response

Incident Response





What is an incident ?

- A security incident is characterized as a **security-related event**—an occurrence affecting the security stance of the ICS environment, which we aim to identify and address.
- The following are some examples of security incidents:
 - Executing malicious code on a system
 - Impaired or disrupted availability of ICS systems or equipment (DCS, SIS, PLC, HMI, SCADA, and more)
 - Malicious or damaging interaction with computing or production resources
 - Unauthorized changes to a PLC or HMI program



What is incident response?

- **Incident response (IR)** encompasses the procedures through which an organization **anticipates and manages** a cybersecurity incident.
- This involves handling the consequences of the incident.
- The primary objective of establishing an IR program or process is to **effectively manage** incidents, thereby mitigating their damage and impact.
- This includes minimizing **recovery time and costs, as well as collateral damage, such as harm to the organization's reputation.**



What is incident response?

- We distinguish
- Incident Response **Processes**
- Incident Response **Procedures**



What is incident response?

- We distinguish :
- Incident Response **Processes**
- **High-level overview:** Incident response processes define the **overall framework** for how an organization will respond to a security incident.
- **Focus:** They establish the **roles, responsibilities, and communication protocols** that guide incident response activities.
- **Flexibility:** Processes are designed to be **adaptable** to different types of incidents and their severity.



What is incident response?

- We distinguish
 - Incident Response **Processes**
 - Incident Response **Procedures**
-
- **Detailed steps:** Incident response procedures provide **specific, step-by-step instructions** for carrying out various tasks within the overall incident response process.
 - **Focus:** They detail the **technical actions** to be taken for containment, eradication, and recovery activities.
 - **Specificity:** Procedures are more **specific** than processes and may vary depending on the type of incident or affected system.



Incident response processes

- There are two distinct aspects to incident response:
- **Incident response preparation**
- **Incident response handling**
- The incident response preparation process occurs **periodically** without any identified incident.
- While the **incident handling** process is **triggered** when an incident is detected.



Incident response preparation process

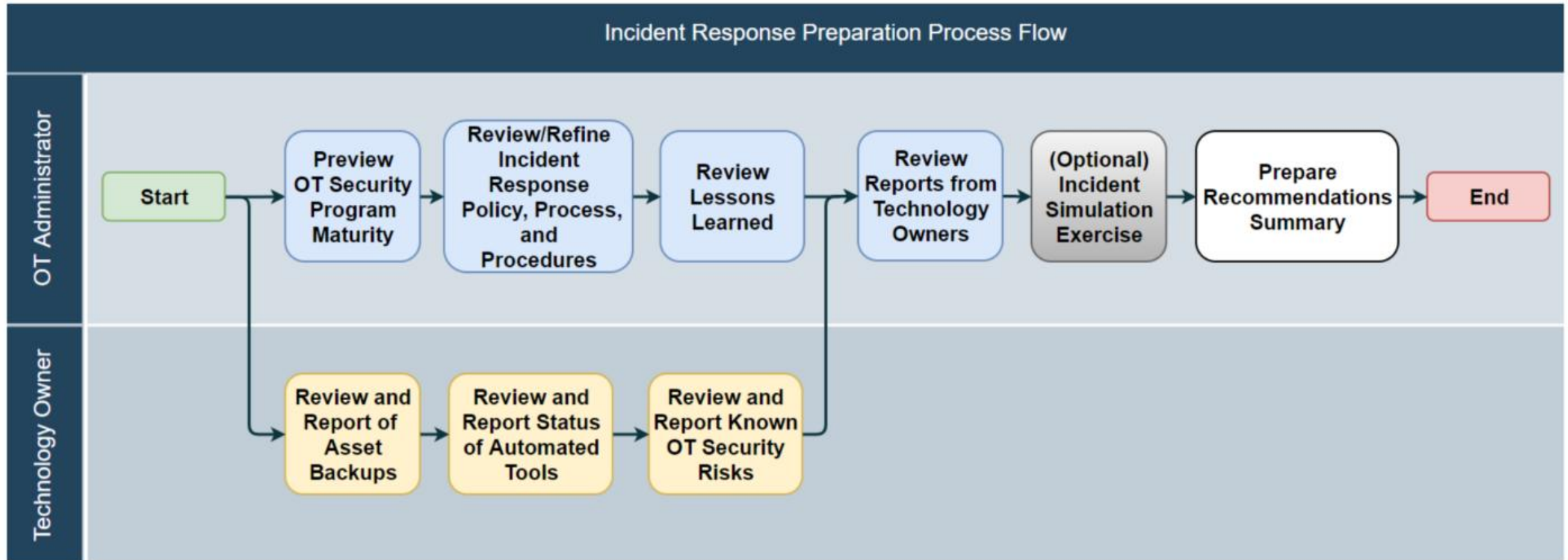
- The goal of the preparation phase of incident response is to prepare the ICS or OT security team to **handle incidents efficiently and effectively**.
- By its nature, the preparation phase occurs separately from any identified incident or event.

It is recommended to follow the incident response preparation process periodically – once a year at a minimum.



Incident response preparation process

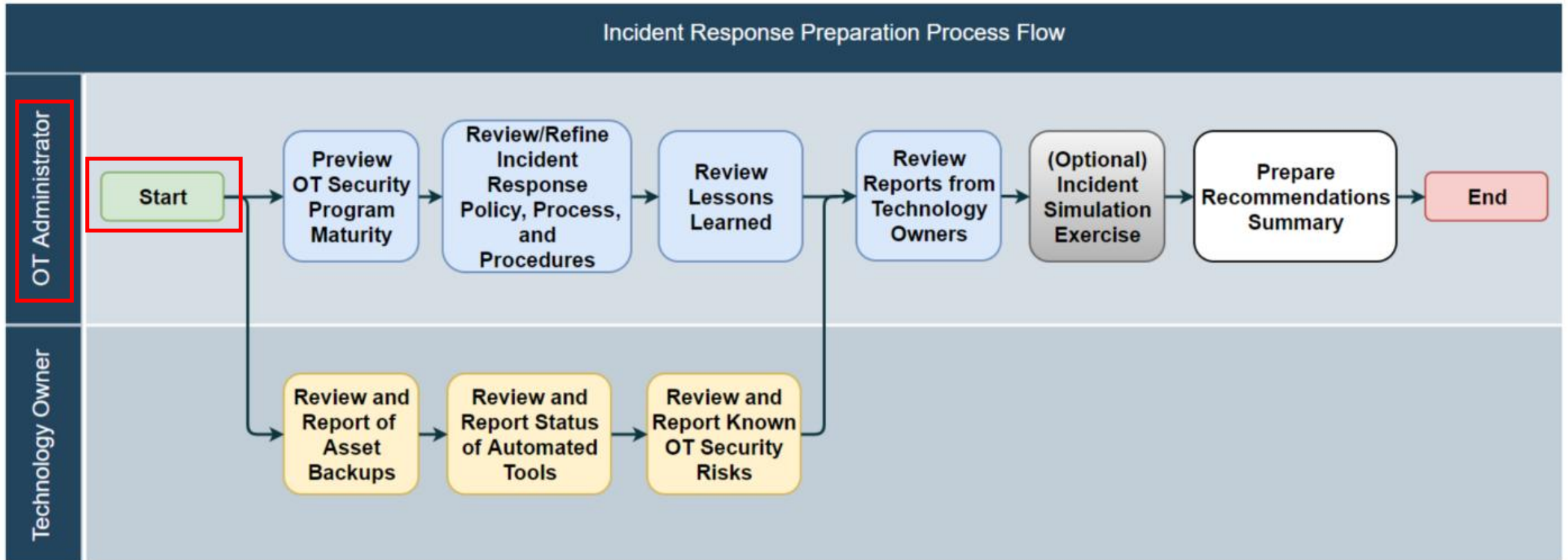
- The following flowchart describes the major steps of the preparation process.





Incident response preparation process

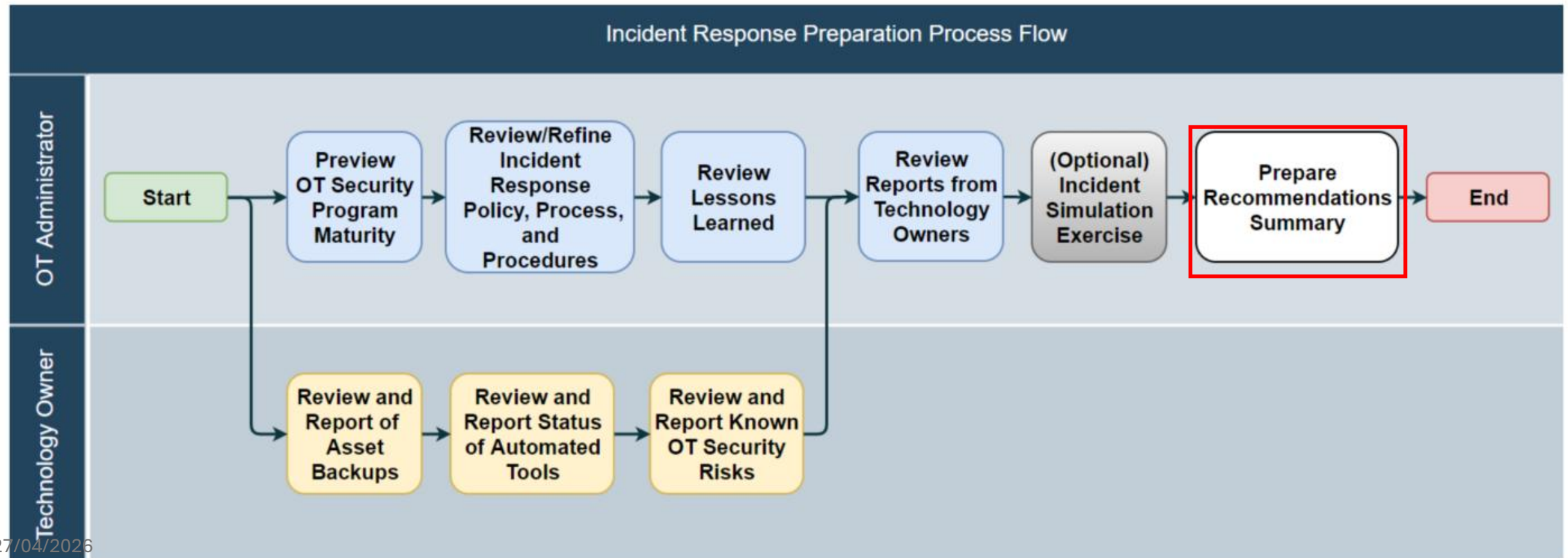
- It shows that the process begins with the OT administrator (the one responsible for OT in a plant/organization).





Incident response preparation process

- The recommendations summary that's prepared at the end of the process is to be kept by the OT administrator and **used during budgeting and resource planning activities.**





Incident response preparation process

- Incident response preparation **inputs**:
- OT security program policies, processes, and procedures
- Asset inventory
- Completed incident response forms

- Incident response preparation **outputs**:
- Modified incident response policy, processes, and procedures
- Recommendations summary document



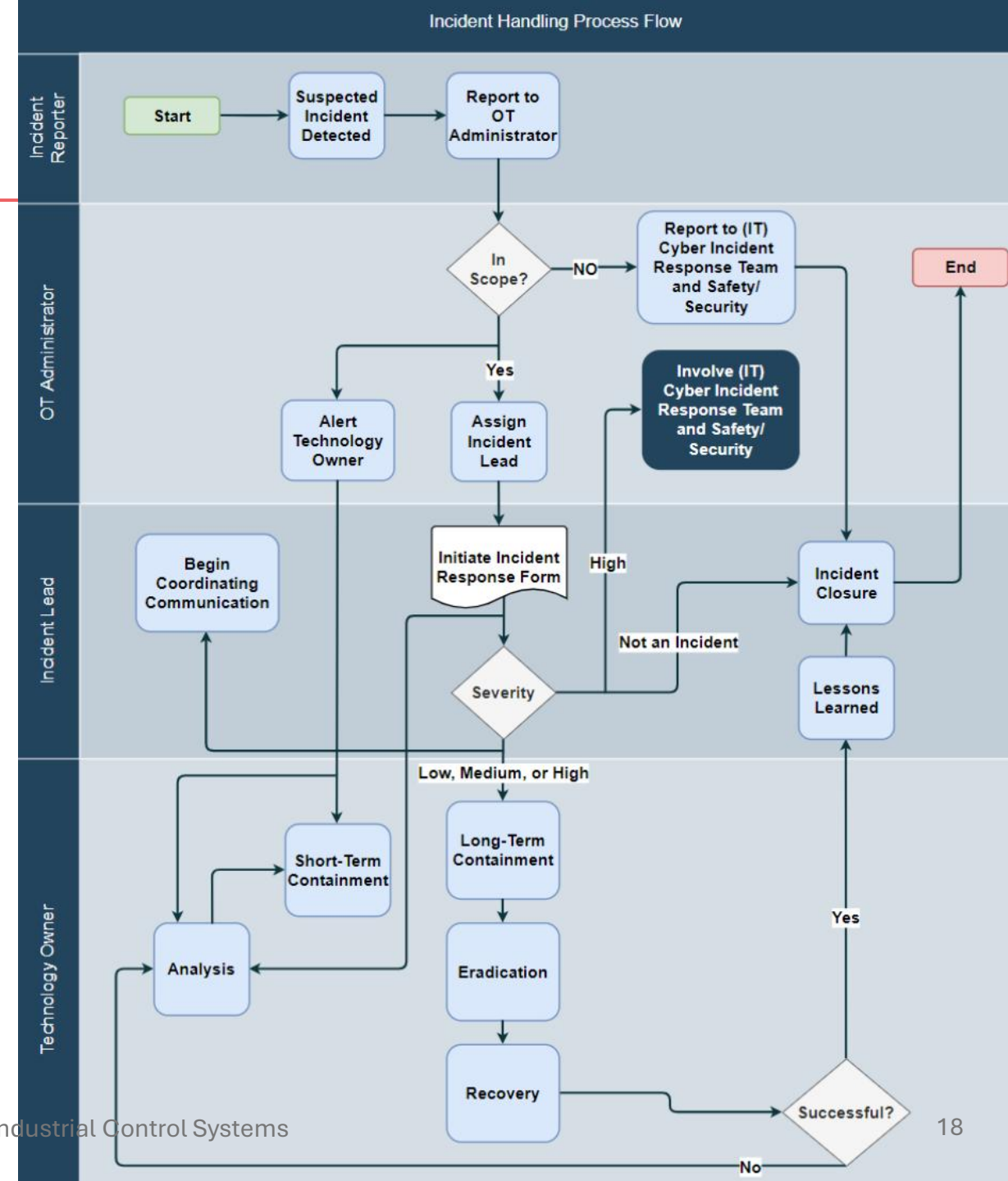
Incident handling process

- By **predefining a process with actions** to be carried out by role holders, the **chaos** surrounding an **incident** can be managed with a **systematic response**.
- If each role holder understands and practices their responsibilities according to the plan, actions and communications are streamlined.



Incident handling process

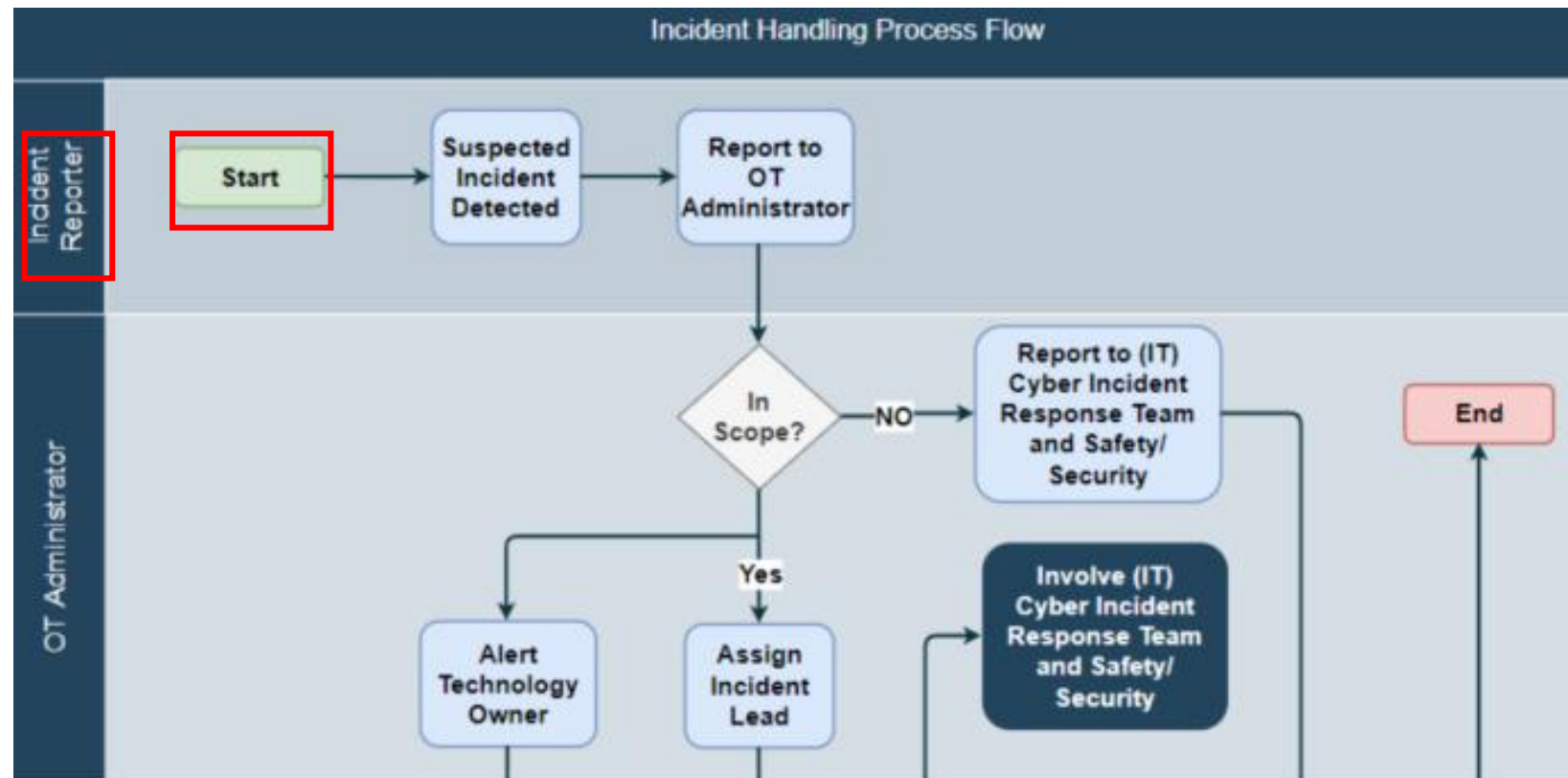
- The following process flow diagram describes the major steps of the incident handling process.





Incident handling process

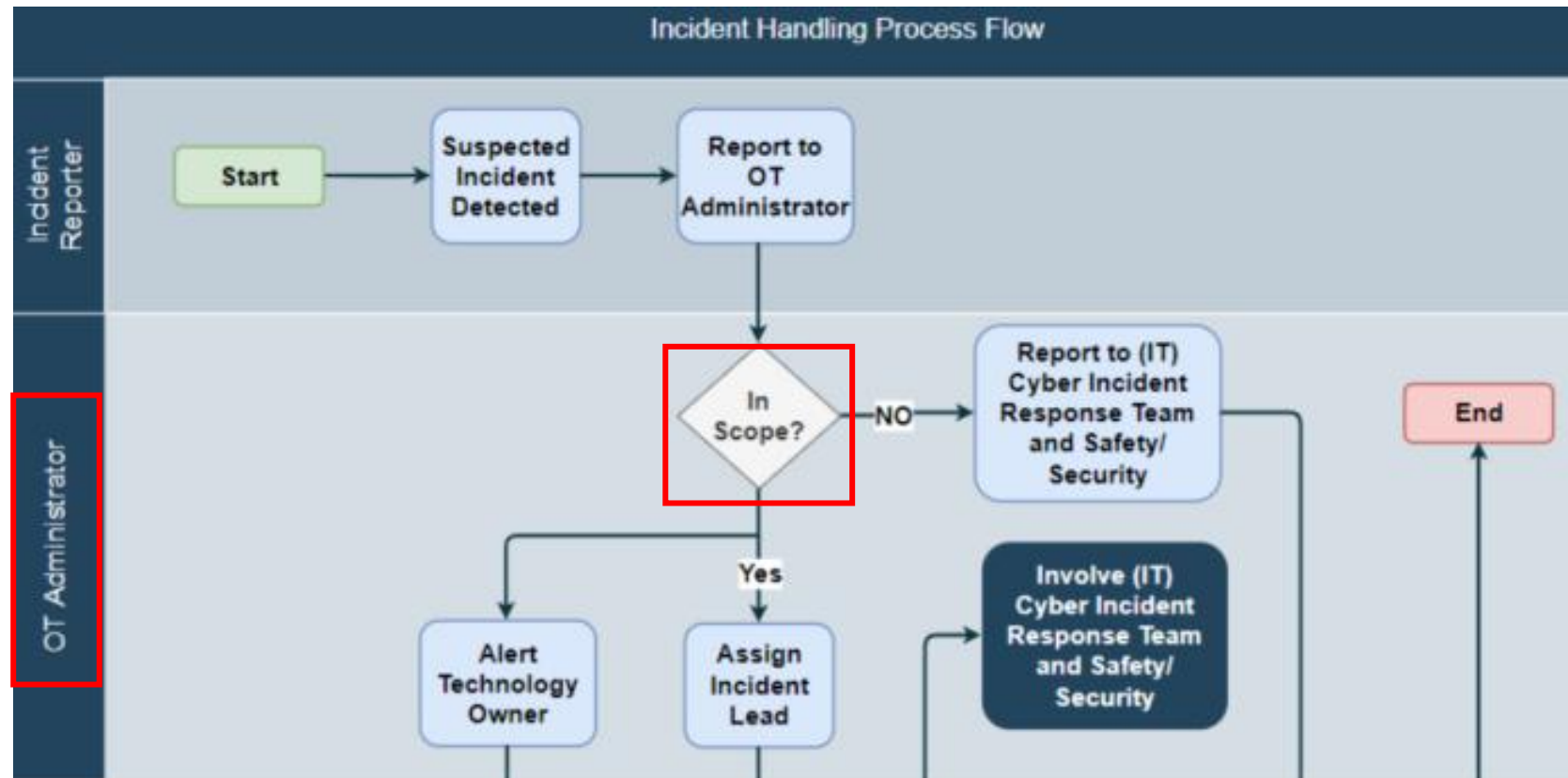
- The process begins with detecting a **suspected incident** by any employee, contractor, or vendor, who is referred to as the **incident reporter**.
- The incident reporter reports the incident to the **OT administrator**, or designated person, by email, phone call, text message, or in person.





Incident handling process

- The OT administrator decides whether the incident is in scope and should be handled by the **OT staff**, or whether it is to be handled by the **IT staff**.
- If in scope for this process, the OT administrator **alerts** the relevant technology owner(s) and **assigns** an incident lead)





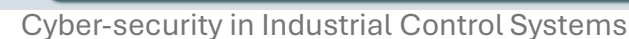
The primary focus is on **preserving critical** operations while minimizing potential **safety risks**.

- Example:
- **Switching to Manual**





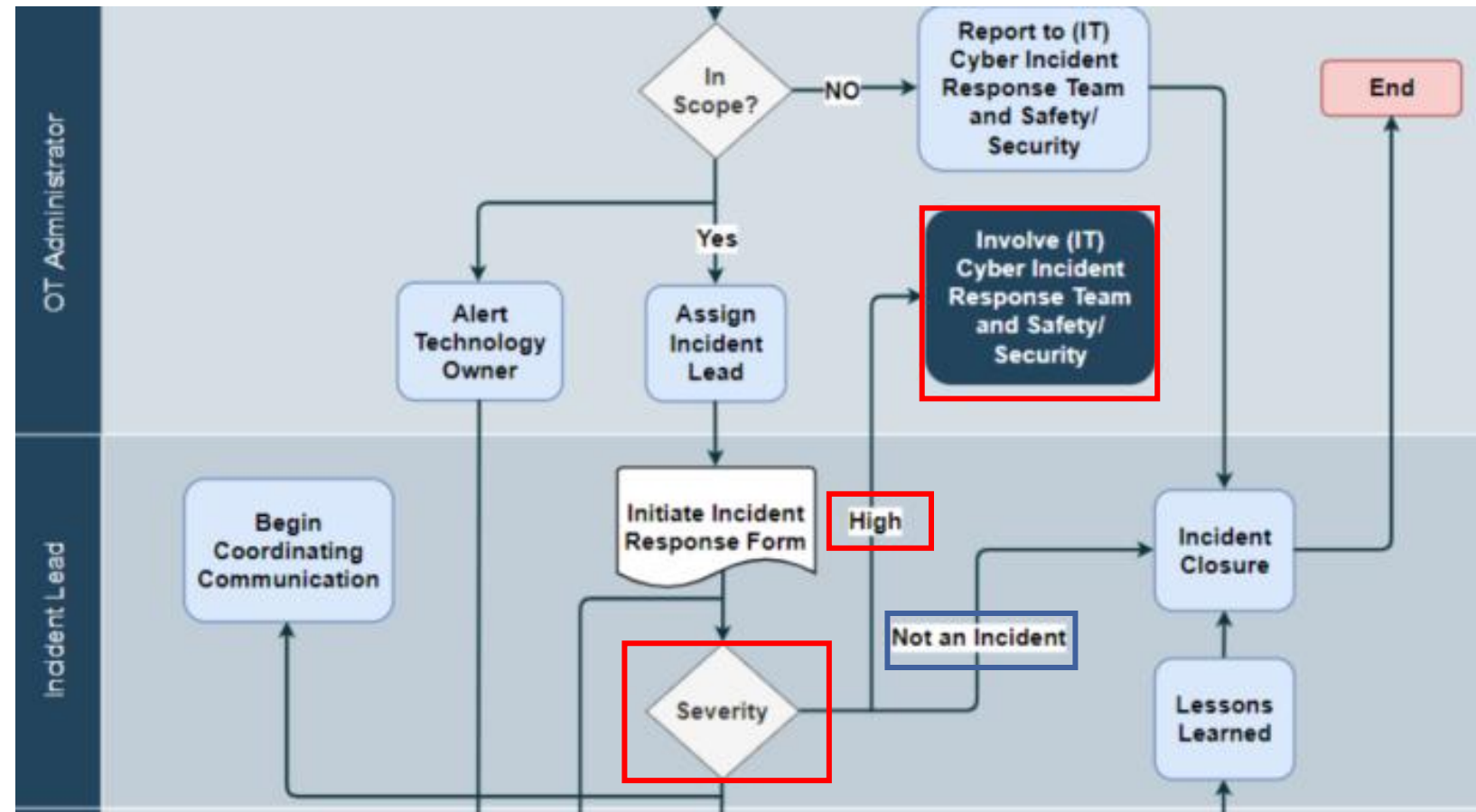
The Incident Lead facilitates a discussion among all relevant parties to determine the **severity** of the incident.





Incident handling process

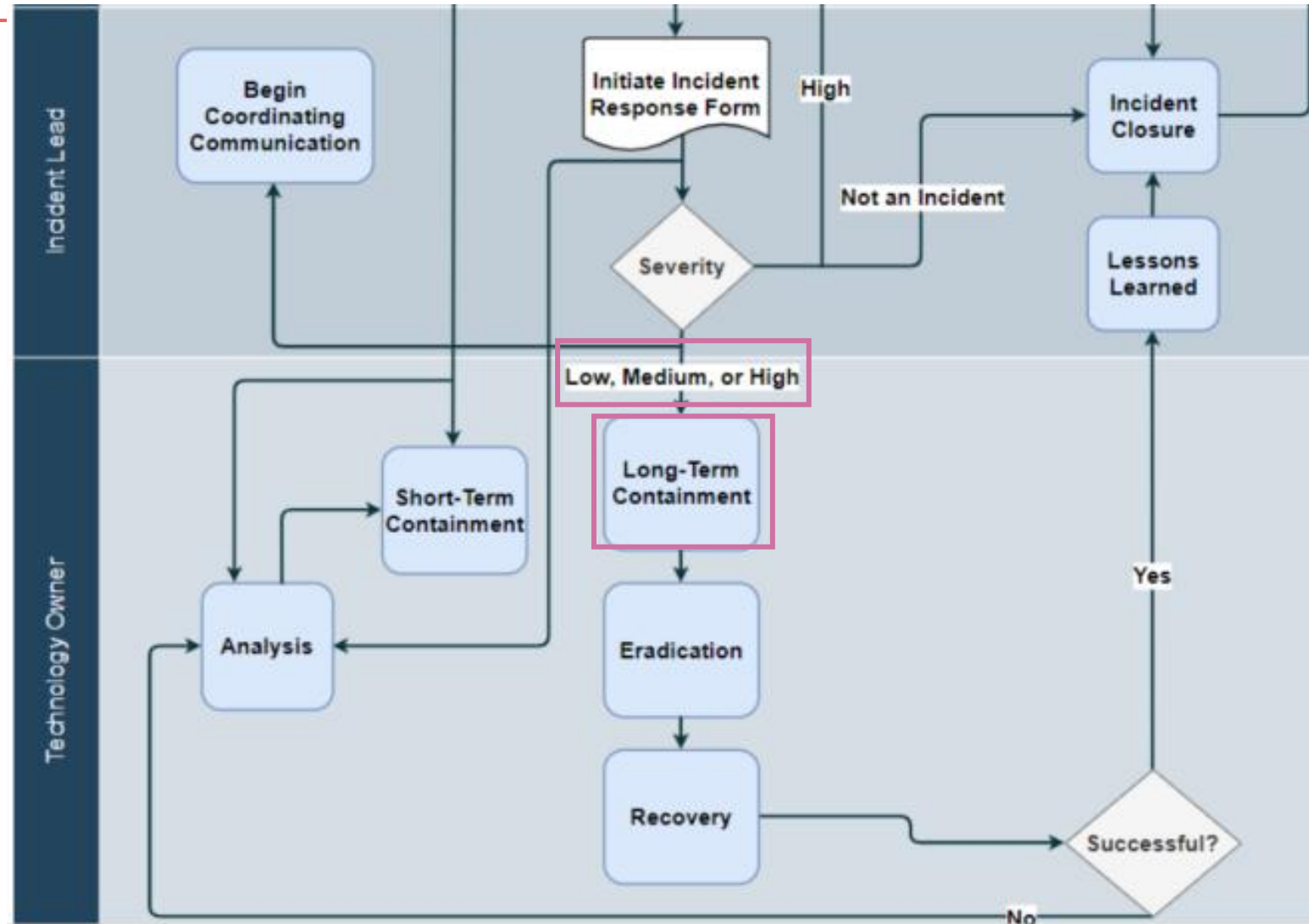
- Not an Incident: the Incident Lead proceed to completing the Incident Response Form and communicating the closed status.
- High: the OT Administrator involves the IT cyber incident response team and safety/security representatives.
- In addition to the following OT measures.





Incident handling process

- **low-, medium:** Technology Owner(s) begins the procedures for **long-term containment**
- They focus on **preventing** future incidents by addressing the **root cause** of the initial attack and implementing more permanent security improvements.





Incident handling process

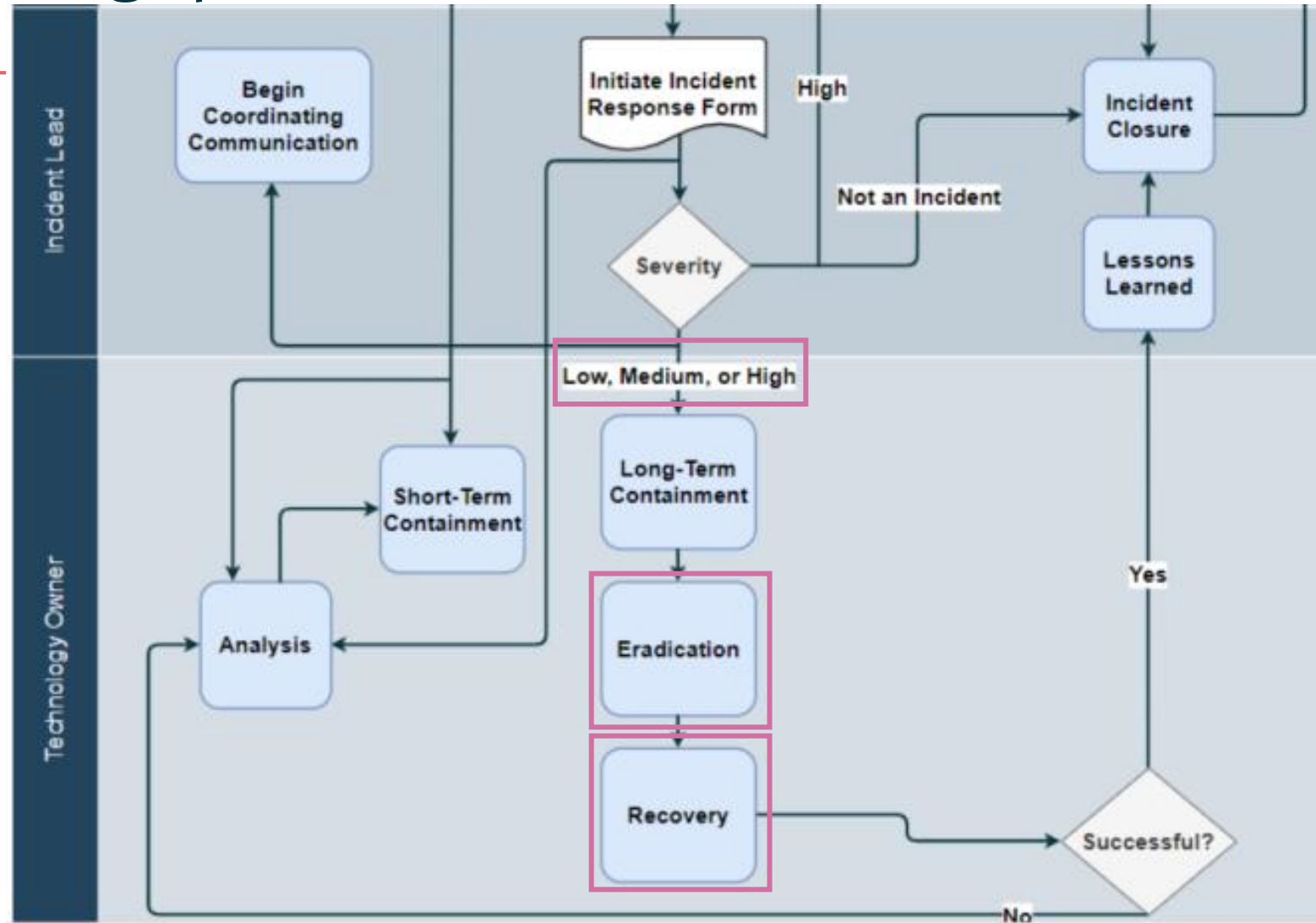
- **low-, medium:** Technology Owner(s) begins the procedures for **long-term containment**.
- They focus on **preventing** future incidents by addressing the **root cause** of the initial attack and implementing more permanent security improvements.
- Here are some examples of long-term containment procedures in ICS security:
- **Patching Systems:** Updating software and firmware with the latest security patches addresses known vulnerabilities that attackers might exploit.
- **Configuration Hardening:** Reviewing and adjusting system configurations to eliminate unnecessary permissions and functionalities that could be abused by attackers.

While short-term containment aims to stop the bleeding, long-term containment looks to mend the wound and prevent future infections.



Incident handling process

- Followed by **eradication**, then **recovery**.
- The Incident Lead continues to gather information to complete the Incident Response Form.





Incident handling process

- During the final step, the **Incident Response Form** is completed by the Incident Lead and submitted to the OT Administrator.
- Then, an incident closed status is communicated:
 - Incident handling **inputs**:
 - Blank incident response form
 - Incident handling **outputs**:
 - Completed incident response form.
 - Normally operating OT environment.
 - Closed incident status is communicated.



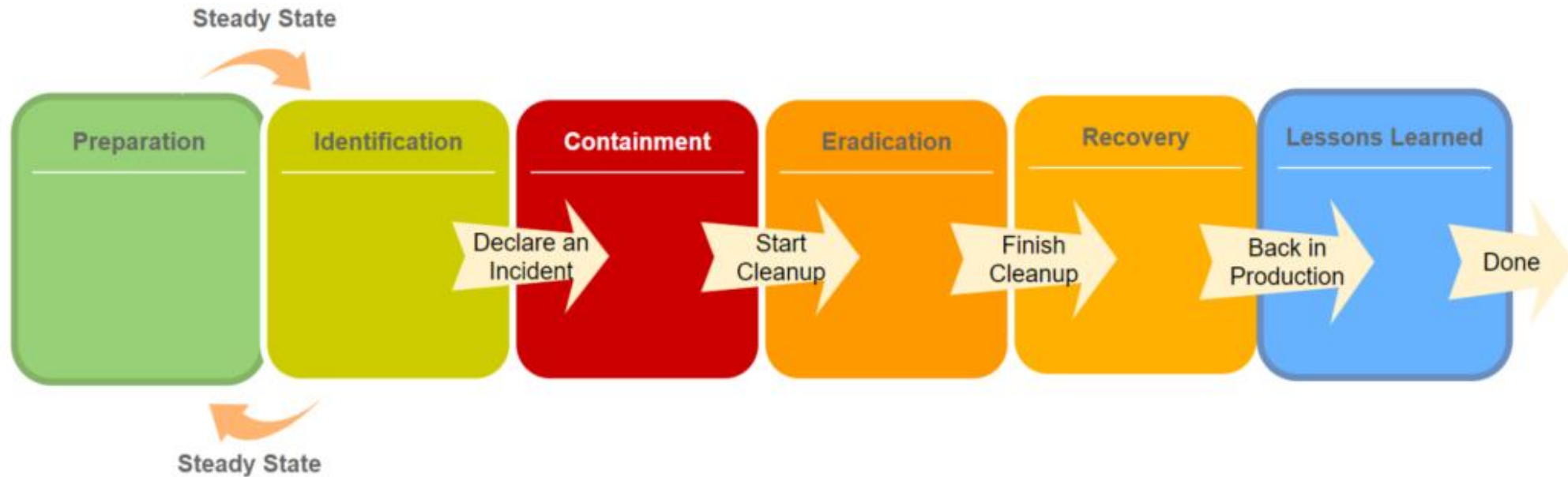
What is incident response?

- We distinguish
- Incident Response **Processes**
- Incident Response **Procedures**



Incident response procedures

- The SANS Institute describes a six-step incident handling process:

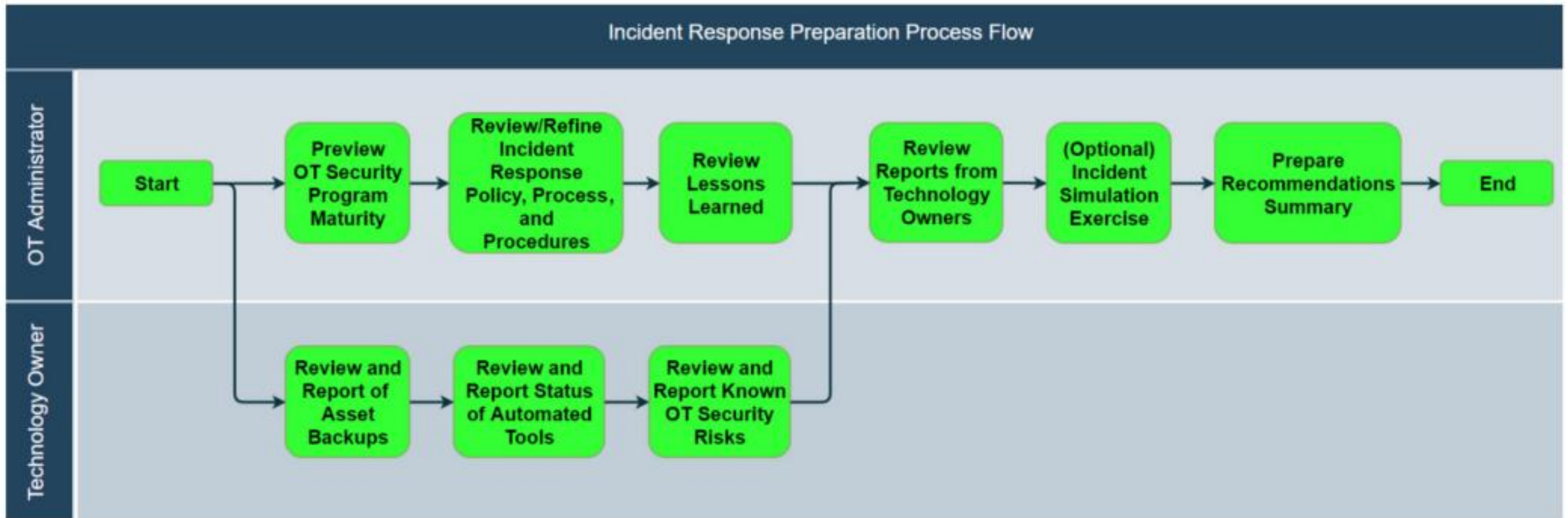


- The first step, **Preparation**, corresponds to **incident response preparation processes** and procedures, while the other **five steps** (**Identification**, **Containment**, **Eradication**, **Recovery**, and **Lessons Learned**) correspond to **incident handling processes** and procedures.



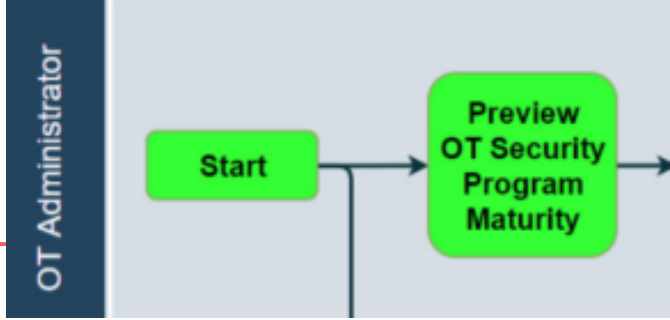
Incident response preparation

- All the tasks of the **incident response preparation** process shown in green are mapped to the preparation step of the SANS Institute six-step incident handling





Incident response preparation



- **Reviewing OT security program maturity**

At a minimum, the following should be surveyed:

- **Governance:**

- Do members of the OT team understand what their OT security program roles and responsibilities are?

- **Training:**

- Have OT security program role members been trained on the policies, processes, and procedures? Has there been a refresher that highlights any recent changes?
- Do OT security program role members have training plans for developing required skills and competencies?
- Has everyone who connects to the OT environment completed security awareness training?

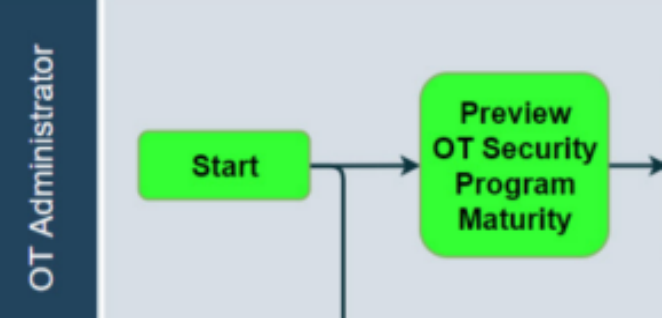


Incident response preparation

- ***Reviewing OT security program maturity***

At a minimum, the following should be surveyed:

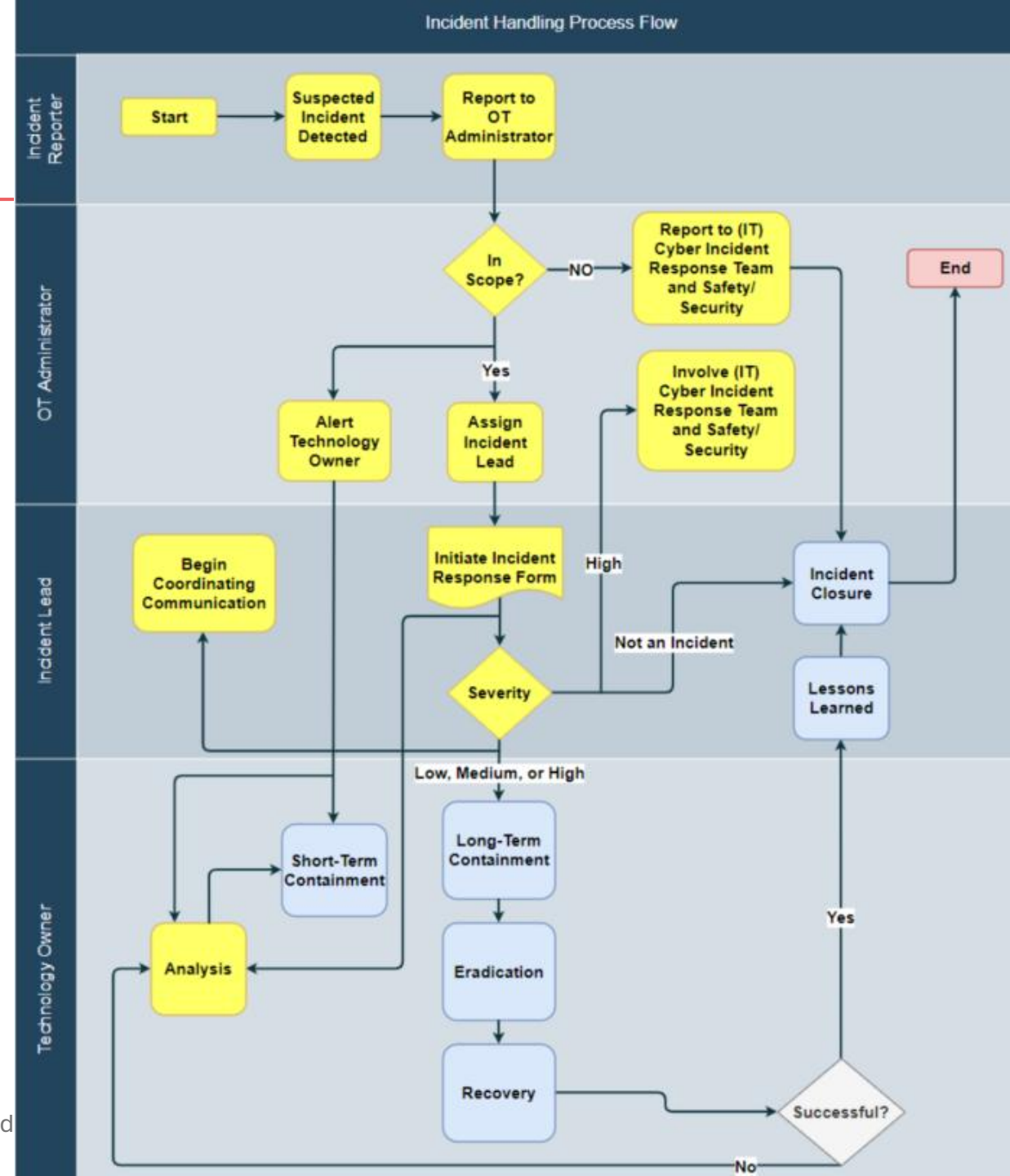
- **Information classification**
- **Operating system and application security patching**
- **Portable media and portable computing**
- **Network architecture**
- **Access control**





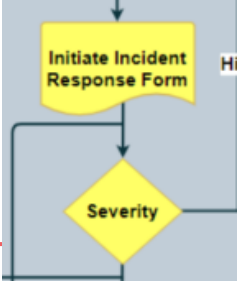
Incident handling procedures

- The **identification procedures** encompass several steps within the incident handling process flow, highlighted in yellow in the diagram below.
- The goals of the identification phase are:
 - Quickly ruling out human error, misconfiguration, and false positives
 - Detecting deviations from the norm
 - Collecting evidence from tools and sources to understand what is occurring
 - Determining the nature and scope of the incident.





Incident handling procedures

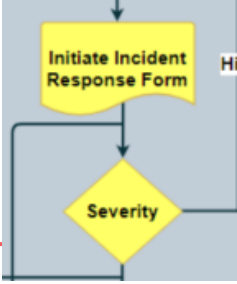


Incident severity determination procedure

- Severity determination is an important step in incident handling because it prescribes who **needs to be involved**, the **appropriate containment procedures**, and the communications plan to execute.
- Incident severity determination should take several factors into account: the **safety** of end users impacted, the **criticality** of the system(s) affected, the **sensitivity** of any data involved, and the **overall impact** on the ability of the company to fulfill its mission.



Incident handling procedures



Incident severity determination procedure

High-severity incident

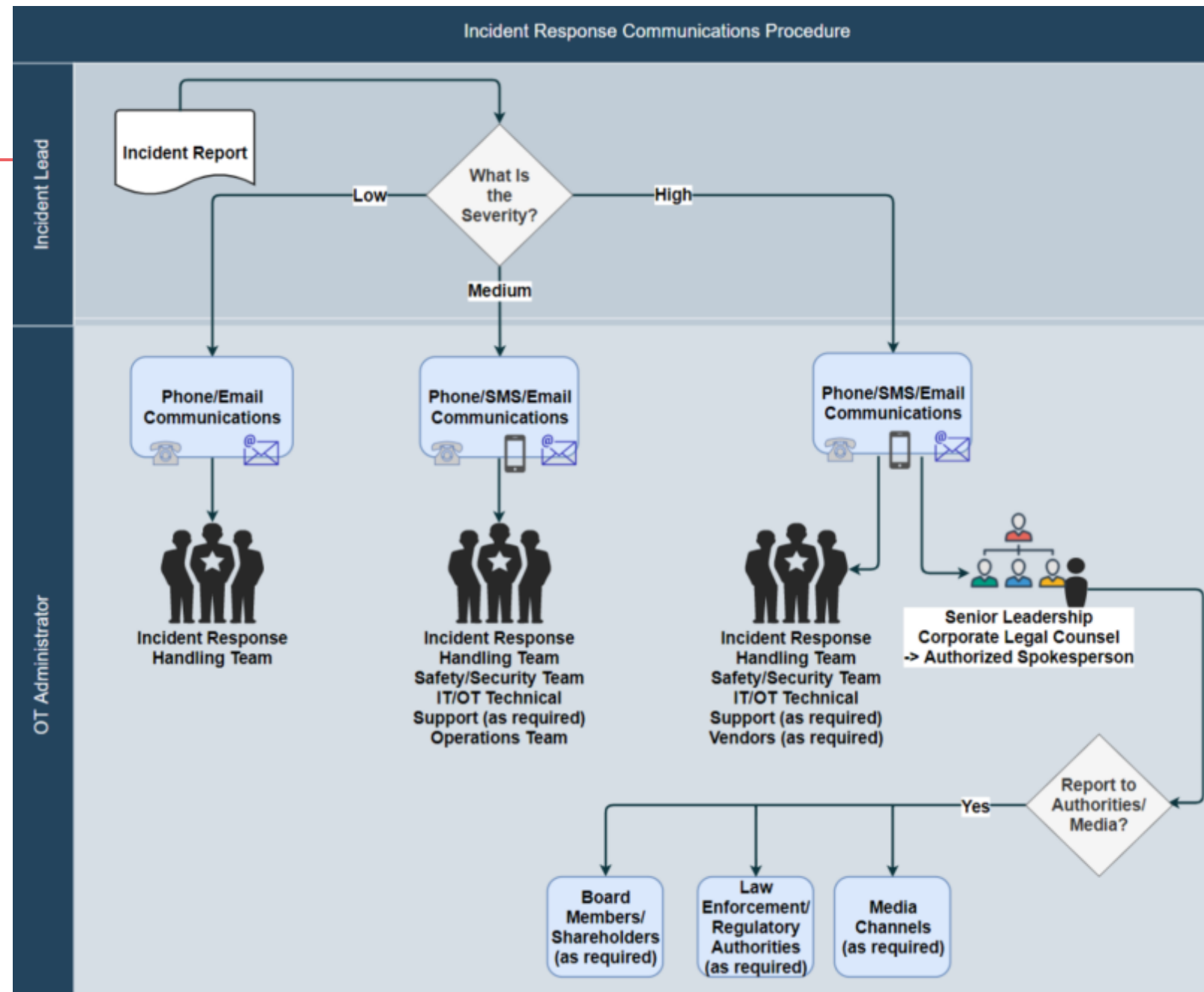
- The incident jeopardizes the **safety** of any individual.
- The incident threatens to impact (or impacts) **production-critical** systems or services.
- The incident poses a serious threat to **financial** risk or legal liability.
- If there is suspicion of **ransomware**.
- If there is a risk of exposing **sensitive** data.
- The incident can **propagate** to or attack other networks, systems, and devices, internally or externally of the plant/facility/department.
- The incident displays **terroristic** threat characteristics or somehow **threatens human life** or company/public property



Incident H.Proc

Incident communications procedure

Once the incident's severity has been determined, the **Incident Lead** begins coordinating communications about the incident per the procedure flow shown in the diagram.

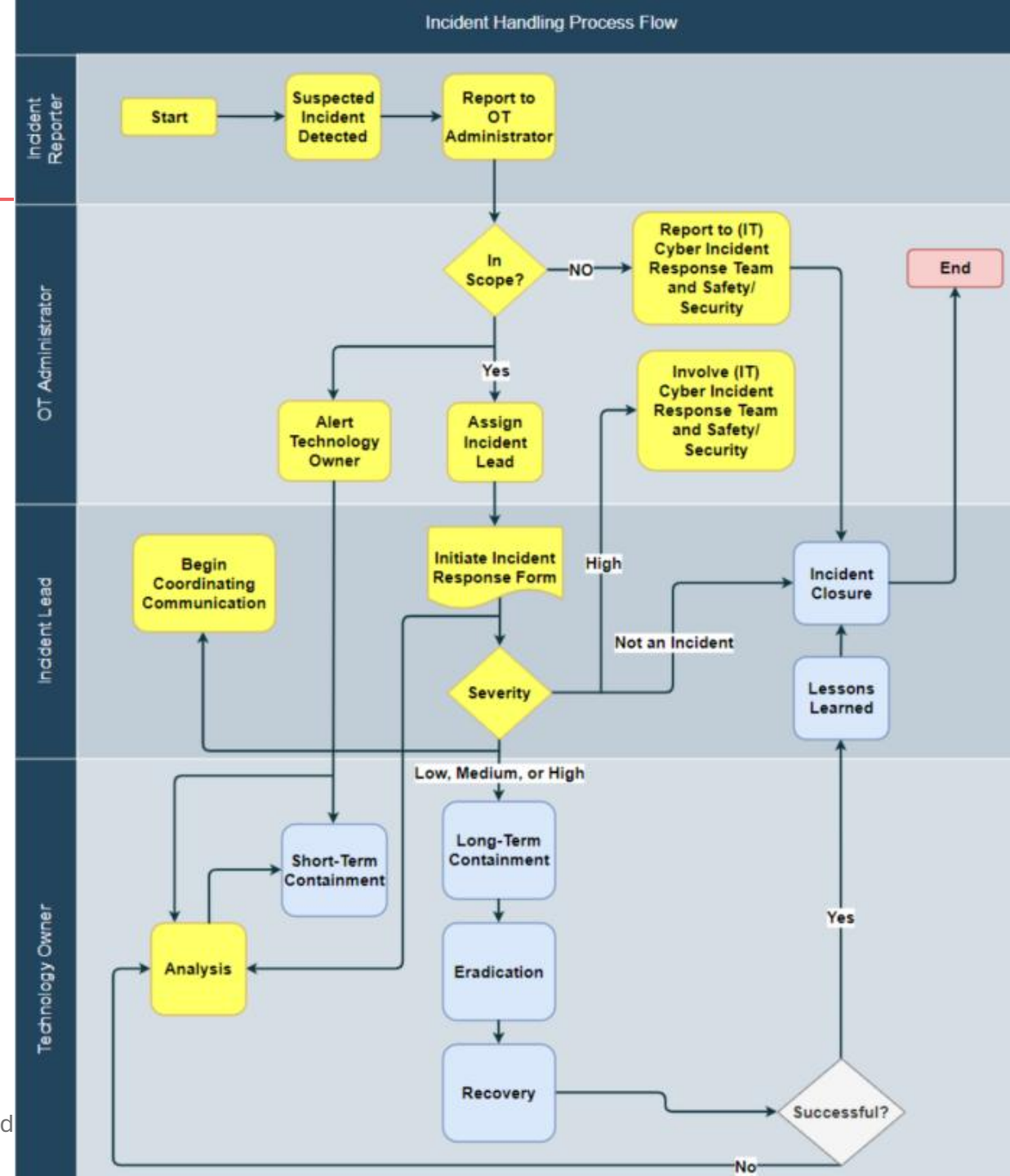




Incident H.Proc

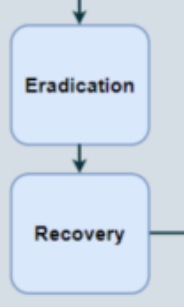
Previously seen

- Short term containment
- Long term containment
- Let's dive in
- Eradication
- Recovery





Incident handling procedures

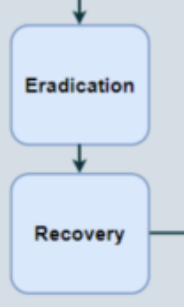


Eradication procedure

- Eradication procedures in ICS security focus on **eliminating** the threat posed by a security incident.
- This involves **removing** the attacker from the system, **neutralizing** any malware or backdoors, and **restoring** affected systems to a clean state
- However, unlike traditional IT environments, ICS security eradication procedures require a **careful balance** between **eliminating threats and maintaining critical operations**.



Incident handling procedures



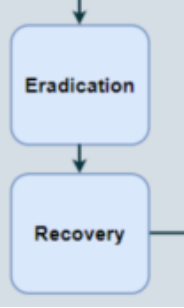
Eradication procedure

key aspects to keep in mind of eradication in ICS:

- **Prioritizing Safety:** The safety of personnel, equipment, and the environment is paramount. Disruptive actions like system reboots or full system wipes might not be feasible if they could cause physical harm.
- **Phased Approach:** Eradication might be a gradual process, especially in complex ICS environments. The focus might be on isolating compromised systems and neutralizing immediate threats first, followed by a more thorough cleanup.
- **Validation and Testing:** After implementing eradication procedures, it's crucial to validate that the threat has been eliminated and that restored systems function correctly.



Incident handling procedures



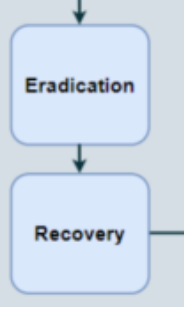
Eradiation procedure

Eradiation can often be achieved by doing one of the following:

- Removing malicious software
- Disabling a breached user account
- Restoring the asset from a clean backup
- Rebuilding the asset from source media
- Eradiation actions should be documented including what was done to which OT asset, when, and by whom.
- Don't proceed to the recovery phase until a root cause has been identified for this security incident and the scope is understood → a significant risk of this or a related security incident occurring again.



Incident handling procedures



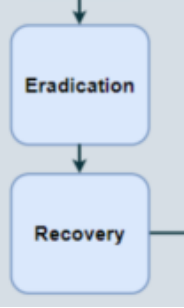
Recovery procedure

The primary goal of the recovery phase is to safely return the affected assets to normal operations.

- **Recovery Procedures**
- **Recovery Verification Procedures**



Incident handling procedures



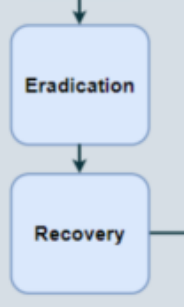
Recovery procedure

The primary goal of the recovery phase is to safely return the affected assets to normal operations.

- **Recovery Procedures**
 - These procedures outline **the steps for restoring** affected systems to a functional state.
- **Recovery Verification Procedures**
 - These procedures **ensure that the recovery** process has been **successful** and that systems are functioning correctly and securely.



Incident handling procedures

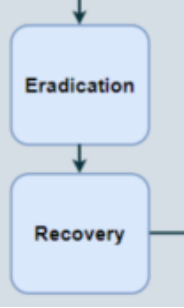


Recovery procedure

- **Recovery Procedures**
- These procedures outline **the steps for restoring** affected systems to a functional state.
- Critical systems and processes should be prioritized for recovery to minimize the impact on operations.
- Recovered systems should be thoroughly tested before being brought back online to ensure they function correctly and are free of residual threats.
- Examples :
 - **Restoring Data from Backups**: If backups are available and known to be clean, they can be used to restore data and configurations on affected systems.
 - **Rebuilding Systems**: In some cases, it might be necessary to rebuild systems from scratch if backups are unavailable or compromised.



Incident handling procedures



Recovery procedure

- **Recovery Verification Procedures**

- These procedures **ensure that the recovery** process has been **successful** and that systems are functioning correctly and securely.
- The results of verification procedures should be **documented** to demonstrate that systems are **operational** and secure.

- Examples :

- **System Integrity Checks:** Verifying system files and configurations to ensure they haven't been tampered with by attackers.
- **Vulnerability Scans:** Scanning recovered systems for any remaining vulnerabilities that could be exploited by attackers.

*For a **low-severity** incident, the **verification period may be brief** (24 hours, at a minimum).*

*A longer verification **of days to weeks** is appropriate for a **medium m- or high-severity**.*



Incident

Field 6 is intended to hold a more **technical description** of the incident based on analysis by the Technology Owner(s).

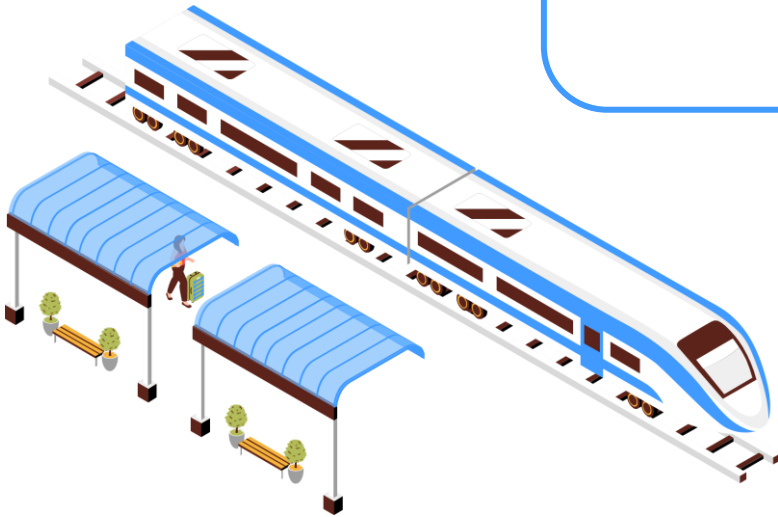
Field 8 holds the **current incident status** as incident handling proceeds.

1	Report no.					
2	Title of report:					
3	Incident reported by:					
4	Date and time of incident:	Date:	Time:			
5	Location of incident:					
6	Description of incident (identify asset/s affected, including corresponding criticality)					
	Asset(s):					
	Criticality:					
	Incident:					
7	Incident lead:					
8	Issue status:					
	(1) Reported	(2) Assigned	(3) Resolved	(4) Closed		
	IT IR case number:					
9	Related incidents:					
10	Category:					
	Malicious code, for example, virus, malware	Denial of service	Detection of unknown software			
	Breach of security procedure or change control	Missing equipment or software	Tampering with equipment or software			
	Unauthorized SCADA system access	Unauthorized physical access				
11	Severity:					
	(1) High	(2) Normal	(3) Low	(4) Not an Incident		
12	Summary of resolution plan:					
13	Planned resolution date:					
14	Summary of lessons learned review:					

If possible, fields 7 through 10 should be completed before or during severity determination

Field 10 is a categorization of a **type of incident**. More than one category may apply, and the categorization **could change as analysis proceeds**.

What about AI





The dual use of AI

AI changes industrial cybersecurity at every level

- AI can help defenders detect, prioritize, and analyze attacks
- AI can also help attackers scale phishing, exploitation, and deception
- AI systems themselves introduce new vulnerabilities
- In OT, this means both **new defensive capabilities** and **new attack surfaces**



AI expands the attack surface of digital and industrial systems

- New components appear in the architecture:
 - LLM APIs
 - vector stores
 - RAG pipelines
 - agents
 - external AI services
- More data flows between trusted and untrusted sources
- More opportunities for prompt injection, leakage, and misuse
- In industrial contexts, connecting AI to OT data may expose sensitive processes



New AI-specific threats

- **AI introduces new classes of threats and vulnerabilities**
- **Threats against AI systems**
 - adversarial examples
 - model extraction
 - Poisoning
- **Threats through AI systems**
 - phishing
 - deepfakes
 - malicious automation
- **Threats from AI integration**
 - prompt injection
 - leakage through RAG or agents
 - unsafe tool use



AI can improve monitoring, correlation, and threat hunting

- Detect anomalies in logs, traffic, and telemetry
 - Correlate weak signals across many sources
 - Prioritize alerts and reduce analyst overload
 - Reconstruct incident timelines faster
 - Support threat hunting by surfacing suspicious patterns
-
- **OT Example**
 - unusual PLC command sequence
 - unusual Modbus or S7 traffic
 - mismatch between sensor readings and actuator commands
 - suspicious IT-to-OT communication path



How to think about AI in industrial cybersecurity

- Use AI only where it matches the task
- Treat AI components as part of the attack surface
- Monitor AI systems like any other critical system
- Never delegate safety-critical decisions blindly to AI
- Keep human oversight for OT operations and incident response

→ **In industrial systems, AI should assist analysis not bypass safety engineering.**



Where AI connects to the course

Lecture	Main question	AI connection
CM1	What are we protecting?	AI adds components and complexity
CM2	What are the threats?	AI adds new threats and misuse cases
CM3	How do we detect attacks?	AI helps anomaly detection and correlation
CM4	How do we respond?	AI helps triage, analysis, and investigation